

BÁO CÁO DỰ ÁN

Hệ thống SecureChat

NGUYỄN VŨ THÀNH

Thanh14704@gmail.com

Lĩnh Vực: Kỹ Sư Phần Mềm: Lập Trình Hệ Thống

Mentor hướng dẫn: Lê Thành Thân

Đơn vị: Viettel Cypher Security

Chương trình: Viettel Digital Talent

HÀ NỘI, 6/2026

TÓM TẮT NỘI DUNG DỰ ÁN

Dự án trình bày việc thiết kế và phát triển hệ thống SecureChat - một giải pháp truyền thông thời gian thực (Real-time Communication) theo mô hình Client-Server. Hệ thống được xây dựng hoàn toàn bằng ngôn ngữ C++ với mục tiêu đáp ứng đồng thời hai yêu cầu : Hiệu năng xử lý đồng thời cao ở mức cao (High Concurrency) và Bảo Mật thông tin đa lớp.

Ở phía Máy chủ (Server), kiến trúc hệ thống được thiết kế dựa trên mô hình điều khiển sự kiện bất đồng bộ (Event-Driven) sử dụng *epoll*, kết hợp cùng mô hình Thread Pool. Điều này cho phép Server xử lý bài toán C10K một cách tối ưu, không bị thất nút cổ chai tại các luồng I/O mạng. Cơ sở dữ liệu SQLite được tích hợp cùng cơ chế Write-Ahead Logging (WAL) giúp đảm bảo tốc độ truy vấn thông tin người dùng và lịch sử hệ thống trong môi trường đa luồng.

Về mặt Giao thức và Bảo mật, hệ thống không sử dụng các giao thức văn bản truyền thống mà lựa chọn sử dụng giao thức truyền tải nhị phân tùy chỉnh (Custom Binary Protocol) với Header chứa mã kiểm lỗi CRC32. Quá trình bảo mật áp dụng mô hình mã hóa lai (Hybrid Crypto): sử dụng RSA-2048 để trao đổi khóa phiên một cách an toàn ở bước bắt tay (Handshake), sau đó toàn bộ payload giao tiếp được mã hóa và xác thực tính nguyên vẹn bằng chuẩn AES-256-GCM.

Ngoài ra, dự án tập trung nghiên cứu và cài đặt một dịch vụ an ninh mạng chủ động ngay trong nhân máy chủ, bao gồm: module Hệ thống phát hiện xâm nhập (Intrusion Detector - IDS) để phân tích hành vi độc hại, bộ định tuyến giới hạn tốc độ (Rate Limiter) chống lại các cuộc tấn công DoS/Spam dựa trên thuật toán Token-Bucket, và Nhật ký kiểm tra (Audit Logger) lưu vết các thao tác nhạy cảm. Phía Client cài đặt giao diện dòng lệnh (CLI) nhẹ, hỗ trợ đa dạng tính năng nghiệp vụ từ nhắn tin cá nhân, phòng chat nhóm, truyền tải tập tin, đến các tập lệnh của quản trị viên (Admin Commands).

Kết quả đạt được là một nền tảng giao tiếp tin cậy, hoạt động ổn định và đáp ứng các tiêu chuẩn bảo mật thực tế, có khả năng mở rộng và tích hợp thêm các dịch vụ khác trong tương lai.

MỤC LỤC

Danh sách hình vẽ	iii
Danh sách bảng	iv
CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI	1
1.1 Khảo sát hiện trạng	1
1.1.1 Đặt vấn đề	1
1.1.2 Mục tiêu và phạm vi của đề tài	2
1.2 Phân tích yêu cầu hệ thống	2
1.2.1 Yêu cầu chức năng	2
1.2.2 Yêu cầu phi chức năng	3
CHƯƠNG 2. NỀN TẢNG LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG	4
2.1 Kiến trúc mạng và giao thức	4
2.1.1 Mô hình Client-Server	4
2.1.2 Giao thức TCP/IP	4
2.2 Công nghệ mã hóa và bảo mật	4
2.2.1 Mã hóa đối xứng AES	4
2.2.2 Mã hóa bất đối xứng RSA	4
2.2.3 Hàm băm SHA256 và xác thực HMAC	4
2.3 Công nghệ xử lý đồng thời và hiệu năng cao	4
2.3.1 I/O Multiplexing và mô hình epoll	4
2.3.2 Mô hình Thread Pool	4
2.4 Lý thuyết phòng thủ và an ninh mạng	4
2.4.1 Hệ thống phát hiện xâm nhập (IDS)	4
2.4.2 Thuật toán Rate Limiting (Token-Bucket)	4
2.5 Hệ thống lưu trữ và cơ sở dữ liệu	4
2.5.1 Cơ sở dữ liệu SQLite	4
2.5.2 Cơ chế Write-Ahead Logging (WAL)	4
2.6 Công cụ và Thư viện phát triển	4

CHƯƠNG 3. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ	
HỆ THỐNG	5
3.1 Kiến trúc tổng thể hệ thống	6
3.1.1 Kiến trúc Server	6
3.1.2 Kiến trúc Client	6
3.2 Thiết kế giao thức giao tiếp	6
3.2.1 Cấu trúc gói tin	6
3.2.2 Luồng xử lý thông điệp	6
3.3 Thiết kế cơ chế bảo mật	6
3.3.1 Cơ chế trao đổi khóa (Key Exchange)	6
3.3.2 Xác thực chứng chỉ số	6
3.4 Thiết kế hệ sinh thái an ninh mạng chủ động	6
3.4.1 Hệ thống phát hiện xâm nhập (IDS)	6
3.4.2 Bộ định tuyến giới hạn tốc độ (Rate Limiter)	6
3.4.3 Nhật ký kiểm toán (Audit Logger)	6
3.5 Thiết kế cơ sở dữ liệu	6
3.5.1 Sơ đồ thực thể liên kết (ERD)	6
3.5.2 Quản lý người dùng và trạng thái	6
3.6 Thiết kế logic tính năng nghiệp vụ	6
3.6.1 Quản lý phòng Chat nhóm (Rooms)	6
3.6.2 Cơ chế truyền tải tập tin (File Transfer)	6
3.6.3 Các tập lệnh quản trị hệ thống (Admin Commands)	6
3.7 Triển khai và Đánh giá	6
3.7.1 Môi trường triển khai	6
3.7.2 Đánh giá kết quả đạt được	6
CHƯƠNG 4. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	7
4.1 Kết luận	7
4.2 Hướng phát triển	7

Danh sách hình vẽ

Danh sách bảng

DANH MỤC THUẬT NGỮ VÀ TỪ VIẾT TẮT

Từ viết tắt	Ý nghĩa
TCP	Transmission Control Protocol
TLS	Transport Layer Security
AES	Advanced Encryption Standard
RSA	Rivest-Shamir-Adleman

CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI

1.1 Khảo sát hiện trạng

1.1.1 Đặt vấn đề

Sự bùng nổ của mạng Internet và các thiết bị kết nối đã làm thay đổi hoàn toàn phương thức giao tiếp của con người. Các ứng dụng nhắn tin và gọi điện trực tuyến (Chat Applications) đã trở thành một công cụ không thể thiếu trong đời sống cá nhân cũng như trong quá trình vận hành doanh nghiệp. Các hệ thống lớn như Zalo, Messenger, Telegram hay WhatsApp hiện đang đáp ứng nhu cầu giao tiếp cho hàng tỷ người dùng thường xuyên trên toàn cầu.

Tuy nhiên, đi kèm với sự phát triển nhanh chóng đó là những thách thức ngày càng nghiêm trọng về an toàn và bảo mật thông tin. Thực tế cho thấy, nhiều hệ thống giao tiếp hiện nay vẫn bộc lộ các lỗ hổng trong khâu lưu trữ và truyền tải dữ liệu. Các cuộc tấn công mạng nhằm đánh cắp danh tính (Identity Theft), nghe lén (Eavesdropping) hay tấn công trung gian (Man-in-the-Middle - MitM) ngày càng trở nên tinh vi. Một số giải pháp phổ biến thường phụ thuộc hoàn toàn vào các giao thức bảo mật lớp vận chuyển (như TLS/SSL) kết hợp với hạ tầng dịch vụ đám mây của bên thứ ba. Mặc dù các cơ chế này cung cấp mức độ bảo vệ cơ bản, nhưng chúng lại không đảm bảo được tính riêng tư tuyệt đối (Absolute Privacy) và không cho phép các tổ chức có yêu cầu an ninh khắt khe làm chủ hoàn toàn luồng dữ liệu của mình.

Thêm vào đó, nhiều nền tảng giao tiếp mã nguồn mở hiện có lại sử dụng các giao thức dựa trên văn bản (Text-based protocols) khá cồng kềnh, gây hao tốn băng thông và gặp nút thắt cổ chai khi phải xử lý đồng thời hàng chục nghìn kết nối (bài toán C10K). Quá trình ghi nhận nhật ký hệ thống (Logging) ở các nền tảng này cũng thường được lưu dưới dạng file văn bản thuần (plain-text) dễ bị chỉnh sửa và xóa dấu vết, thiếu đi cơ chế kiểm toán chặt chẽ để truy vết nguồn gốc khi xảy ra sự cố rò rỉ dữ liệu.

Từ những hiện trạng nêu trên, việc nghiên cứu và tự xây dựng một hệ thống máy chủ trò chuyện (Chat Server) với kiến trúc đa luồng tối ưu, sử dụng giao thức truyền tải tự định nghĩa (Custom Protocol) cùng các lớp mã hóa bảo mật từ tận mức ứng dụng (áp dụng các thuật toán chuẩn như AES, RSA, HMAC) là vô cùng cấp thiết. Một giải pháp đồng bộ từ tầng mạng đến tầng ứng dụng không chỉ giúp làm chủ hoàn toàn công nghệ lõi mà còn tạo ra một môi trường giao tiếp đáng tin cậy,

chống lại các hành vi giả mạo và cung cấp khả năng kiểm toán chống can thiệp (Tamper-evident Auditing).

1.1.2 Mục tiêu và phạm vi của đề tài

1.2 Phân tích yêu cầu hệ thống

1.2.1 Yêu cầu chức năng

Dựa trên mục tiêu xây dựng một nền tảng trò chuyện bảo mật toàn diện, hệ thống cần đáp ứng các nhóm yêu cầu chức năng cốt lõi sau:

- **Quản lý phiên kết nối và người dùng:** Hệ thống phải hỗ trợ người dùng kết nối (Connect), ngắt kết nối (Disconnect) và duy trì trạng thái hoạt động thông qua cơ chế nhịp tim (Ping/Pong). Hệ thống cũng cần cho phép người dùng tra cứu danh sách những tài khoản đang online và xem thông tin chi tiết (Whois) của một người dùng cụ thể.
- **Giao tiếp và Nhắn tin:**
 - *Nhắn tin cá nhân (Private Chat):* Cho phép hai người dùng trao đổi thông điệp trực tiếp với nhau một cách bảo mật.
 - *Nhắn tin nhóm (Room Chat):* Hỗ trợ tính năng tra cứu danh sách phòng (List Rooms), tạo phòng mới (Create Room), tham gia (Join), rời phòng (Leave) và gửi tin nhắn quảng bá (Broadcast) tới tất cả các thành viên trong phòng.
- **Truyền tải tệp tin (File Transfer):** Hệ thống cần tích hợp tính năng gửi và nhận tệp tin P2P hoặc thông qua server. Quá trình này bao gồm các bước kiểm soát chặt chẽ: gửi yêu cầu truyền tệp (File Request), chấp nhận/từ chối (Accept/Reject), và truyền dữ liệu theo từng khối (File Data) để không gây nghẽn luồng thông điệp chính.
- **Quản trị hệ thống (Admin Commands):** Cung cấp đặc quyền cho quản trị viên thực hiện các thao tác kiểm duyệt, quản lý cộng đồng như: kích xuất người dùng (Kick), cấm chat (Mute), cấm truy cập (Ban), thăng cấp quản trị (Promote) và gửi thông báo toàn hệ thống (System Broadcast).
- **Thiết lập bảo mật sơ khởi:** Chức năng tự động thực hiện bắt tay mật mã (Crypto Handshake) ngay khi có kết nối mới nhằm trao đổi khóa công khai và

thiết lập kênh truyền mã hóa trước khi bất kỳ dữ liệu nghiệp vụ nào được phép lưu thông.

1.2.2 Yêu cầu phi chức năng

Bên cạnh các tính năng nghiệp vụ, hệ thống đặc biệt chú trọng vào các yêu cầu phi chức năng nhằm đảm bảo hiệu năng, độ tin cậy và an toàn thông tin tuyệt đối trong môi trường mạng thực tế:

- **Bảo mật và Toàn vẹn dữ liệu (Security & Integrity):**

- Mọi thông điệp truyền tải trên mạng lưới phải được mã hóa bằng thuật toán chuẩn công nghiệp (AES) với khóa phiên (Session Key) được phân phối an toàn qua cơ chế mã hóa bất đối xứng (RSA).
- Hệ thống phải chống lại được các hành vi đánh tráo, thay đổi nội dung gói tin thông qua việc sử dụng mã xác thực thông điệp (HMAC) kết hợp cùng hàm băm SHA256.
- Tích hợp hệ thống ghi nhận nhật ký kiểm toán chống can thiệp (Tamper-evident Audit Logger) lưu trữ trên cơ sở dữ liệu SQLite, cho phép truy vết chính xác và hệ thống sẽ báo động nếu file log bị chỉnh sửa trái phép từ bên ngoài.
- Có module Phát hiện xâm nhập (Intrusion Detector) để tự động nhận diện và ngắt kết nối các client có hành vi gửi gói tin dị thường, sai cấu trúc hoặc có dấu hiệu tấn công từ chối dịch vụ (DoS).

- **Hiệu năng và Khả năng mở rộng (Performance & Scalability):** Máy chủ phải được thiết kế theo kiến trúc hướng sự kiện (Event-driven) sử dụng vòng lặp bất đồng bộ (Event Loop) kết hợp với mô hình đa luồng (Thread Pool). Điều này đảm bảo luồng chính của hệ thống không bị nghẽn (non-blocking) bởi các thao tác I/O chậm chạp, đáp ứng khả năng xử lý hàng chục nghìn kết nối đồng thời (bài toán C10K) với độ trễ xử lý (Latency) ở mức thấp nhất.

- **Tính tin cậy và Khả năng chịu lỗi (Reliability & Fault Tolerance):** Máy chủ phải có cơ chế xử lý mượt mà các tình huống phân mảnh gói tin TCP (TCP Packet Fragmentation) hoặc dính gói. Nếu phía client đột ngột mất mạng, hệ thống phải tự động nhận diện thông qua cơ chế timeout của Ping/Pong và dọn dẹp tài nguyên (socket, session) để ngăn chặn hoàn toàn rò rỉ bộ nhớ (Memory Leak).

CHƯƠNG 2. NỀN TẢNG LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG

2.1 Kiến trúc mạng và giao thức

2.1.1 Mô hình Client-Server

2.1.2 Giao thức TCP/IP

2.2 Công nghệ mã hóa và bảo mật

2.2.1 Mã hóa đối xứng AES

2.2.2 Mã hóa bất đối xứng RSA

2.2.3 Hàm băm SHA256 và xác thực HMAC

2.3 Công nghệ xử lý đồng thời và hiệu năng cao

2.3.1 I/O Multiplexing và mô hình epoll

2.3.2 Mô hình Thread Pool

2.4 Lý thuyết phòng thủ và an ninh mạng

2.4.1 Hệ thống phát hiện xâm nhập (IDS)

2.4.2 Thuật toán Rate Limiting (Token-Bucket)

2.5 Hệ thống lưu trữ và cơ sở dữ liệu

2.5.1 Cơ sở dữ liệu SQLite

2.5.2 Cơ chế Write-Ahead Logging (WAL)

2.6 Công cụ và Thư viện phát triển

CHƯƠNG 3. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

3.1 Kiến trúc tổng thể hệ thống

3.1.1 Kiến trúc Server

3.1.2 Kiến trúc Client

3.2 Thiết kế giao thức giao tiếp

3.2.1 Cấu trúc gói tin

3.2.2 Luồng xử lý thông điệp

3.3 Thiết kế cơ chế bảo mật

3.3.1 Cơ chế trao đổi khóa (Key Exchange)

3.3.2 Xác thực chứng chỉ số

3.4 Thiết kế hệ sinh thái an ninh mạng chủ động

3.4.1 Hệ thống phát hiện xâm nhập (IDS)

3.4.2 Bộ định tuyến giới hạn tốc độ (Rate Limiter)

3.4.3 Nhật ký kiểm toán (Audit Logger)

3.5 Thiết kế cơ sở dữ liệu

3.5.1 Sơ đồ thực thể liên kết (ERD)

3.5.2 Quản lý người dùng và trạng thái

3.6 Thiết kế logic tính năng nghiệp vụ

3.6.1 Quản lý phòng Chat nhóm (Rooms)

3.6.2 Cơ chế truyền tải tập tin (File Transfer)

3.6.3 Các tập lệnh quản trị hệ thống (Admin Commands)

CHƯƠNG 4. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

4.1 Kết luận

4.2 Hướng phát triển